PDV WEB · SISTEMA DE PONTO DE VENDA

Requisitos Não Funcionais

Como o sistema deve se comportar: segurança, desempenho, consistência, auditoria, interoperabilidade, implantação e qualidade — com meta mensurável, forma de verificação e situação atual.

Documento	DOC-02 · Requisitos Não Funcionais	**Versão**	2.0 — 28/10/2026
Equipe	Hugo de Oliveira Guimarães, Jean Wictor, Cesar Franco		
Situação anterior	Os requisitos não funcionais estavam espalhados: validações VAL-06 e VAL-07, seção 1.9 do Plano (riscos) e a menção "Arquitetura Docker/AWS, atualização em tempo real e segurança criptográfica". Este documento os consolida.		
Classificação	Baseada nas características de qualidade da ISO/IEC 25010		

1. Resumo

ID	Requisito	Característica (ISO 25010)	Meta	Situação
RNF-01	Autenticação segura	Segurança	Senhas só em hash BCrypt; token assinado, válido por 24 h; bloqueio após tentativas erradas	**Atendido**
RNF-02	Autorização por perfil	Segurança	100% das operações administrativas negadas ao Vendedor	**Atendido**
RNF-03	Privacidade e proteção de dados (LGPD)	Segurança	Tráfego HTTPS; nenhum dado sensível em logs ou respostas de erro	**Parcial (certificado TLS no ambiente)**
RNF-04	Desempenho (VAL-07)	Eficiência de desempenho	p95 < 3 s em consulta de estoque e finalização de venda, inclusive com 20 operadores simultâneos	**Atendido (local)**
RNF-05	Consistência sob concorrência (VAL-08)	Confiabilidade	Nenhuma venda do mesmo saldo em duplicidade	**Atendido**
RNF-06	Integridade transacional e financeira	Confiabilidade	Operações atômicas; valores exatos em centavos	**Atendido**
RNF-07	Auditabilidade	Segurança (responsabilização)	100% das ações sensíveis registradas	**Atendido**
RNF-08	Interoperabilidade (API REST)	Compatibilidade	Contrato v2.3: JSON, RFC 7807, paginação padronizada	**Atendido**
RNF-09	Implantação em containers (Docker / AWS EC2)	Portabilidade	Subida com um comando (Docker Compose)	**Pronto, não executado**
RNF-10	Disponibilidade e tratamento de falhas	Confiabilidade	Health check público; falhas de banco → 503 sem detalhes; sessões e bloqueios preservados em reinícios	**Atendido**
RNF-11	Manutenibilidade e testabilidade	Manutenibilidade	Cobertura ≥ 80% das linhas e ≥ 70% dos ramos; esquema versionado	**Atendido**
RNF-12	Usabilidade	Usabilidade	Mensagens em português, claras e acionáveis; operação ágil no caixa	**Parcial (front-end)**

2. Detalhamento

RNF-01 — Autenticação segura

Segurança

Requisito	O acesso a qualquer funcionalidade exige autenticação por CPF e senha (Regra 2.3, VAL-06).
Critérios	• Senhas armazenadas apenas como hash BCrypt; nunca em texto, nunca devolvidas pela API. • Token JWT assinado (HS256) com validade de 24 h. A aplicação não inicia sem uma chave secreta de pelo menos 32 caracteres. • Respostas de login idênticas, inclusive no tempo, para CPF inexistente e senha errada. • Logout, renovação, inativação e mudança de perfil invalidam tokens anteriores. A lista de tokens revogados fica no banco: vale após reinício e entre várias instâncias. • Token expirado é recusado (tolerância de 30 s para diferença de relógio). • Proteção contra força bruta: 5 senhas erradas por CPF ou 20 por IP em 15 min bloqueiam o login por 15 min (HTTP 429 com `Retry-After`). CPF inexistente é bloqueado igual, para não revelar quem é usuário. A senha do gerente usada no desconto tem o mesmo limite, por vendedor. Todo bloqueio é auditado.
Verificação	CT-AUTH-001 a 009, CT-AUTH-U01 a U06, CT-SEG-001 a 004, CT-SEG-009 a 017, CT-SEG-019, CT-VEN-U24 — **aprovados**

RNF-02 — Autorização por perfil

Segurança

Requisito	Vendedores só vendem, cadastram clientes e consultam; ações administrativas são exclusivas do Gerente (VAL-02).
Critérios	• Permissão verificada em duas camadas: no filtro de segurança, antes de ler a requisição, e no controller. • O Vendedor recebe 403 nas rotas do Gerente, nunca um erro de validação que revele regras internas. • O Vendedor não acessa caixas, vendas nem comissões de outros vendedores trocando o identificador na URL.
Verificação	CT-SEG-005 (9 rotas), CT-SEG-006, CT-API-007, CT-HIS-001/002, CT-COM-002 — **aprovados**

RNF-03 — Privacidade e proteção de dados (LGPD)

Segurança

Requisito	Dados pessoais de clientes e funcionários (CPF/CNPJ, e-mail) devem ser protegidos (VAL-06).
Critérios	• Tráfego protegido por HTTPS no ambiente de produção. Com `PDV_EXIGIR_HTTPS=true` a API redireciona HTTP para HTTPS e envia HSTS (1 ano); cabeçalhos `X-Content-Type-Options`, `X-Frame-Options` e `Cache-Control` em todas as respostas. • Respostas de erro sem SQL, stack trace ou dados de conexão. • Logs de tentativa de login com CPF mascarado (4 últimos dígitos). • Testes usam somente CPF/CNPJ sintéticos, nunca documentos de pessoas reais.
Verificação	CT-API-008/009, CT-AUTH-U04, CT-USR-001, CT-SEG-018, CT-SEG-020 — **aprovados**. Certificado TLS: **pendente** (proxy/balanceador do ambiente AWS)

RNF-04 — Desempenho (VAL-07)

Eficiência de desempenho

Requisito	Consultas de estoque, inclusão de itens e finalização de vendas devem ser concluídas em menos de 3 segundos.
Critérios	Percentil 95 abaixo de 3.000 ms com 1.000 produtos cadastrados; consultas paginadas (máximo de 100 itens por página).
Resultado medido	Listar 1.000 produtos: p95 74 ms · busca por nome: 36 ms · venda com 10 itens: 59 ms · consulta unitária: 9 ms · **carga com 20 operadores simultâneos** (consulta + venda, 440 requisições, 148 req/s): p95 281 ms, pior requisição 981 ms, 0 erros
Proteção	A aplicação aquece o pool de conexões e as consultas principais antes de aceitar tráfego; sem isso a primeira rajada após a subida chegava a 4 s (DEF-WEB-006).
Verificação	CT-PERF-001 a 005 — **aprovados** em ambiente local. Pendente: teste de carga (JMeter) na infraestrutura AWS.

RNF-05 — Consistência sob concorrência (VAL-08)

Confiabilidade

Requisito	Vendas simultâneas não podem vender o mesmo saldo duas vezes (risco "Consistência de Estoque" do Plano, 1.9).
Critérios	• Produtos bloqueados no banco durante a finalização da venda, sempre na mesma ordem (sem impasse/deadlock). • Cancelamentos, sangrias e aberturas de caixa simultâneos também são serializados. • O banco impede estoque negativo e mais de um caixa aberto por operador, mesmo que a aplicação falhe.
Verificação	CT-CONC-001 (repetido 10 vezes a cada execução): 20 vendas simultâneas com estoque 5 → exatamente 5 concluídas. CT-CONC-002 a 004, CT-SEG-019, CT-DB-002/003 — **aprovados**
Observação	A reserva de saldo enquanto o item está no carrinho (estoque tripartido) foi adiada para a próxima fase (ADR-001, D-02).

RNF-06 — Integridade transacional e financeira

Confiabilidade

Requisito	Operações financeiras devem ser exatas e completas, nunca parciais.
Critérios	• Valores em `BigDecimal` / `NUMERIC(10,2)`, nunca em ponto flutuante; arredondamento comercial em centavos. • Venda, itens, baixa de estoque e auditoria numa única transação; qualquer falha desfaz tudo. • O banco garante total = subtotal − descontos e total ≥ 0. • Preço praticado sempre vem do catálogo; vendas são imutáveis após o registro.
Verificação	CT-CALC-001 a 008, CT-VEN-012/013, CT-DB-004, CT-AUD-004 — **aprovados**

RNF-07 — Auditabilidade

Segurança

Requisito	Toda ação sensível deve deixar registro com usuário, data/hora, tipo de ação e valores anterior/novo (Regra 1.2).
Critérios	25 tipos de ação auditados (inclui `ACESSO_BLOQUEADO` e `AUTORIZACAO_FALHA`); o registro é gravado na mesma transação da operação; consulta restrita ao Gerente.
Verificação	CT-AUD-001 a 004, CT-PROD-006/008, CT-USR-004, CT-CAN-002 — **aprovados**

RNF-08 — Interoperabilidade (API REST)

Compatibilidade

Requisito	O backend expõe uma API REST conforme a Documentação da API v2.3, consumível por qualquer front-end.
Critérios	• JSON em `snake_case`; datas ISO-8601 com fuso −03:00. • Erros no padrão RFC 7807 com `invalid_params`; códigos HTTP 400, 401, 403, 404, 405, 409, 422 e 503 com significado fixo. • Listagens com `pagina`, `limite`, `total_registros`, `total_paginas` e `dados`. • PUT substitui o recurso; PATCH altera parcialmente; DELETE faz exclusão lógica.
Verificação	CT-API-001 a 012, CT-PAG-001 a 005, CT-PROD-011, CT-SMK-001 a 003 — **aprovados**

RNF-09 — Implantação em containers (Docker / AWS EC2)

Portabilidade

Requisito	O sistema roda containerizado (Docker Compose) numa instância AWS EC2.
Critérios	• Imagem com build em duas etapas, executada por usuário sem privilégios, no fuso America/Sao_Paulo. • Configuração somente por variáveis de ambiente (nenhum segredo no código). • O esquema do banco é criado e atualizado automaticamente (Flyway) ao subir. • Executa em Linux e Windows (Java 25); scripts com fim de linha LF garantido.
Verificação	**Pendente** — Dockerfile e docker-compose escritos; execução prevista no roteiro RT-DEP-01 a 05. A API já rodou como servidor HTTP real (modo demonstração) e passou num smoke de 14 passos; a bateria tem pipeline Linux (GitHub Actions).

RNF-10 — Disponibilidade e tratamento de falhas

Confiabilidade

Requisito	O sistema deve indicar sua saúde e tratar falhas sem expor detalhes.
Critérios	Endpoint público `/actuator/health` para o balanceador; demais endpoints de monitoramento fechados; banco indisponível → 503; erro inesperado → 500 genérico. Prontidão só depois do aquecimento; desligamento gracioso (requisições em andamento terminam, até 20 s); revogações e bloqueios guardados no banco sobrevivem a reinícios.
Verificação	CT-SMK-001, CT-SEG-008, CT-SEG-011, CT-API-008/009 — **aprovados**

RNF-11 — Manutenibilidade e testabilidade

Manutenibilidade

Requisito	O código deve ser organizado, testável e com evolução controlada.
Critérios	• Código organizado por módulo de negócio (venda, caixa, produto…) e camadas (controller, serviço, repositório). • Cobertura mínima verificada no build: 80% das linhas e 70% dos ramos. • Esquema do banco versionado (Flyway); decisões de arquitetura registradas (ADR). • Testes de integração com banco real que não exigem Docker nem banco instalado.
Resultado	Cobertura de 96,8% das linhas e 87,6% dos ramos; 100% dos mutantes cobertos detectados (12 classes); pipeline de integração contínua em Linux — **atendido**

RNF-12 — Usabilidade

Usabilidade

Requisito	Operação ágil na frente de caixa e mensagens compreensíveis (Plano 1.10).
Critérios	• Mensagens de erro em português, indicando o campo e o motivo (ex.: "Estoque atual é 1, mas foi solicitado 3."). • Busca de produto por código ou nome; leitura por código de barras (EAN). • Telas do Vendedor e do Gerente com alertas visuais de estoque crítico.
Verificação	Mensagens: **verificadas** nos testes de API. Telas: **pendente** (front-end, Ciclo 2).